

SIMATSENGINEERING

ASSESSMENTTOOL3–Scenario-Based

COURSENAME:EthicalHacking COURSECODE:ITA14

CO2|Weightage:30%|Duration:90min|TotalMarks:50

COURSEOUTCOMECOVERED

CO2: Foot printing Tools – Conducting Competitive Intelligence, DNS Zone Transfers, IntroductiontoSocialEngineering:SocialEngineeringAttacksandCountermeasures.(BT4)

QUESTIONS

Topic1:FootprintingTools–ConductingCompetitiveIntelligence Q1.

(L3 – Apply) – 15 Marks

Acybersecurityconsultanthasbeenassignedtoperformapassivesecurityassessmentfora company named

ABCTechnologies.Theconsultantmustcollectpubliclyavailableinformationwithoutdirectly interacting withthecompany'sservers.

Task:Applysuitablefootprintingtoolstoidentifythecompany's:

o domainregistrationdetails,

o employeeemailaddresses,

o technologystack,

o andpubliclyexposedsubdomains.

Explainhoweachselectedtoolhelpsinconductingcompetitiveintelligence. Topic 2:

DNS Zone Transfers

Q2.(L3 –Apply)–15Marks

Duringanauthorizedpenetrationtest,asecurityanalystsuspectsthatthetargetorganization's DNS server is

misconfiguredandmayallowunauthorizedDNSzonetransfers.

Task:ApplytheappropriateDNScommandortooltoverifywhetherzonetransfersare permitted. If the transfersucceeds,explainhowtheretrievedDNSrecordscanbeusedtoidentifyinternalhosts, mail servers,

andsubdomainsduringreconnaissance.

Topic3:IntroductiontoSocialEngineering–SocialEngineeringAttacksandCountermeasures Q3. (L3 – Apply) – 20 Marks

EmployeesofanorganizationreceiveanemailclaimingtobefromtheITdepartment,asking them to verify

theirlogincredentialsthroughaprovidedlinkbecauseofanurgentsecurityupdate.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Code of Conduct:

I G.Jaswanth Krishna (192472366) (Name/RegNo) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **G.Jaswanth Krishna**

ANSWERS

Q1. Footprinting Tools–Competitive Intelligence

Scenario: A cybersecurity consultant must perform a passive security assessment for ABC Technologies. Only publicly available information is to be collected (no direct interaction with company servers).

1.1 Understanding the Requirement

Passive footprinting means gathering information from open sources without sending packets to the target. This is standard for competitive intelligence and early reconnaissance in authorized assessments.

1.2 Tools and Their Use

Domain registration details

- Tool: WHOIS (whois command/whois.icann.org/whois.com)
- What it reveals: Registrar, registrant organization, creation/expiration dates, nameservers, sometimes admin contact.
- Value for competitive intelligence: Confirms ownership, age of domain, and related domains registered by the same entity.

Employee email addresses

- Tool: theHarvester (or public search/LinkedIn/company website “Contact” and “Team” pages)
- What it reveals: Email patterns (e.g., firstname.lastname@abctech.com), employee names linked to the company.
- Value: Helps map organizational structure and later identify possible phishing targets in authorized tests only.

Technology stack

- Tool: BuiltWith, Wappalyzer, or WhatWeb
- What it reveals: Webserver, CMS, frameworks, analytics, CDN, programming languages used on public sites.
- Value: Shows which technologies the company relies on; useful for understanding public attack surface without active scanning.

Publicly exposed subdomains

- Tool: Sublist3r, Amass (passive modes), or Certificate Transparency logs (crt.sh)
- What it reveals: Subdomains such as mail., vpn., dev., staging. that appear in public DNS or certificates.
- Value: Expands the known public footprint and may reveal forgotten or less-protected systems.

Passive Footprinting for Competitive Intelligence

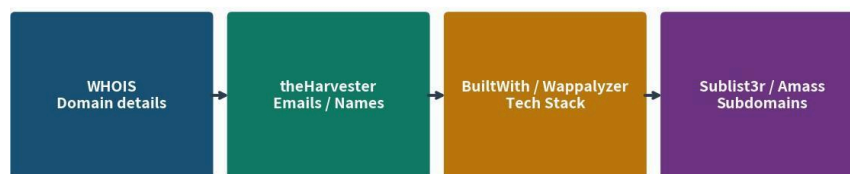


Figure 1: Common passive footprinting tools used for competitive intelligence

1.3 How These Tools Support Competitive Intelligence

Together they give a public picture of the organization's online presence, technology choices, and contact surface. This information is collected only from public sources and is used in authorized assessments to understand exposure without touching the target systems.

Q2. DNS Zone Transfers

Scenario: During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

2.1 Understanding the Issue

A DNS zone transfer (AXFR) is the method used by secondary name servers to copy the full zone data from a primary server. When zone transfers are not restricted, any external host can request the complete list of DNS records. This is a classic misconfiguration found during authorized reconnaissance.

2.2 Appropriate Command/Tool to Verify

Step 1 – Identify the authoritative name servers:

- `nslookup -type=NS targetdomain.com`
- `dig NS targetdomain.com`

These commands return the list of nameservers (NS records) responsible for the domain. Step 2

– Attempt a zone transfer against each name server:

- `dig axfr @ns1.targetdomain.com targetdomain.com`
- `host -l targetdomain.com ns1.targetdomain.com`

If the server is properly locked down, the response will be “Transfer failed” or “REFUSED”. If the transfer succeeds, the full zone file is returned. These checks are performed only inside an authorized penetration test scope.

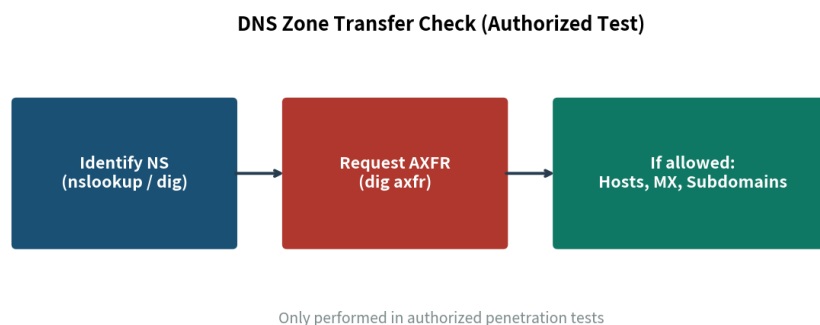


Figure 2: High-level steps to check for open zone transfer (authorized testing only)

2.3 What Retrieved DNS Records Reveal

When an unauthorized zone transfer is possible, the analyst receives a complete map of the DNS zone. The most useful record types for reconnaissance are:

- **A and AAAA records**—Link hostnames to IPv4/IPv6 addresses. This quickly lists internal or publicly reachable hosts (web, app, database, jump servers, etc.).
- **MX records**—Identify the mail servers that handle email for the domain. These become important targets for further authorized email-related testing.

- NSandCNAMerecords–Showadditionalnameserversandaliases. Aliasesoftenpointto staging, development, or CDN systems that may be less hardened.
- TXTrecords–MaycontainSPF,DKIM,verificationtokens,orotherconfigurationdatathat reveals email security posture.
- SRVrecords(if present)–CanexposeservicelocationssuchasVoIP,directoryservices,or collaboration tools.
- Subdomainnames–Everyhostnameinthezoneexpandstheattacksurfacemapandhelpsthe tester prioritize systems for later phases.

2.4 HowThisHelpsReconnaissance

Thezonefileactsasaninternaldirectoryofsystems.Fromittheauthorizedtester can:

- BuildacompletelistofhostsandtheirIPAddresseswithoutactivenetworkscanning.
- Identifymailinfrastructureforlaterauthorizedtesting.
- Discoverforgottenorpoorlymaintainedsubdomains(dev,test,backup,oldapplications).
- Understandtheorganization'snamingconventions,whichoftenrevealdepartmentorfunction.

All of this information is obtained passively from the DNS server once zone transfer is allowed, making it highly valuable in the reconnaissance phase of an authorized assessment.

2.5 RecommendedFix(forthereport)

Zone transfers should be restricted to a short list of trusted secondary name servers only. Public or unrestricted AXFR must be disabled. This finding should be reported as a medium-to-high severity misconfiguration.

Q3.SocialEngineering –PhishingAttack&Countermeasures

Scenario: Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

3.1 IdentificationoftheAttack

This is a Phishing attack, specifically a credential-harvesting phishing email. It belongs to the broader category of social engineering attacks.

Keyindicatorsthatconfirmtheattacktype:

- Impersonation–ThemessagepretendstocomefromtheinternalITdepartment, atrusted source.
- Urgency–Languagesuchas“urgentsecurityupdate”isdesignedtopushtheuserintoacting without thinking.
- Requestforcredentials –Theemailaskstheusertoenterlogindetailsonalink,whichisnevera normal IT practice for routine updates.
- Unsolicitedlink–Asuddenrequesttoclickandverifyisaclassicphishingpattern.

Thegoaloftheattackeristostealusernamesandpasswordssotheycanaccessinternalsystems,email, or cloud accounts.

3.2 SuitableCountermeasuresEmployeesShouldFollow

Beforerespondingtoorclickinganythingintheemail,employeeesshouldapplythefollowingpractical checks:

- Inspect the sender address carefully – Look at the actual email address, not only the display name.AreallTmessagewillnormallyusetheofficialcompanydomain.Slightspellingchanges or free email domains are warning signs.

- Hoverover(orlong-press)thelink–Withoutclicking, examinetherealURL.Lookformisspelled domains, strange subdomains, or IP addresses instead of the company name.
- Donotactonurgencyalone–LegitimateITteamsalmostneverdemandimmediatepassword entry through an email link for a “security update.” Urgency is a social-engineering pressure tactic.
- Verify through a second channel – Contact the IT helpdesk or security team using a phone numberorchattoolthat isalreadyknownandtrusted.Donot useanycontactdetailssuppliedin the suspicious email.
- Reportthessage–Forwardtheemail(asanattachmentifpossible)tothesecurityorIT mailbox so the team can block the sender and alert other staff.
- Neverentercredentialsonapagereachedfromanunexpectedemail –Officialpassword changes or MFA setup are done through known portals or after proper verification.
- Enableandusemulti-factorauthentication(MFA)–Evenifapasswordisstolen,MFAgreatly reduces the chance of account takeover.

Phishing Email – Countermeasures



Figure3:Practicalcountermeasuresagainstphishingemails

3.3 HowTheseActionsPreventCredentialTheft

Eachcountermeasurebreaksastepintheattacker’sprocess:

- CheckingthesenderandtherealURLstopstheuserfromreachingafakeloginpage.
- Resistingurgencyremovestheemotionalpressurethatcausespeopletothinkwithoutthinking.
- VerifyingwithITthroughanotherchannelconfirmswhethertherequestisgenuinebeforeany password is typed.
- Reportingtheemailallowstheorganizationtoblockthecampaign,warnotheremployees, and reduce the overall success rate of the attack.
- MFAensuresthatastolenpasswordaloneisnotenoughtoaccesstheaccount.

Together,thesehabitsconvertadangerousemailintoareportedincidentinsteadofasuccessfulcredential theft.

3.4 OrganizationalSupport(AdditionalContext)

While the question focuses on employee actions, organizations also support prevention through security awareness training, email filtering, DMARC/SPF/DKIM, and clear reporting channels. Employee vigilance remains the last and most important line of defense when a phishing email reaches the inbox.

3.5 Conclusion

The described email is a classic phishing (credential-harvesting) social-engineering attack. By carefully checkingthesender,inspectinglinks,refusingtoactonfalseurgency,verifyingthroughatrustedchannel,

reporting the message, and using MFA, employees can effectively prevent credential theft and protect both themselves and the organization.

Rubrics Alignment (for examiner reference)

Understanding of Scenario • Identification of Key Issues • Application of Concepts (tools, DNS commands, phishing type) • Decision Making (countermeasures)
• Clarity of Response – structured with diagrams.